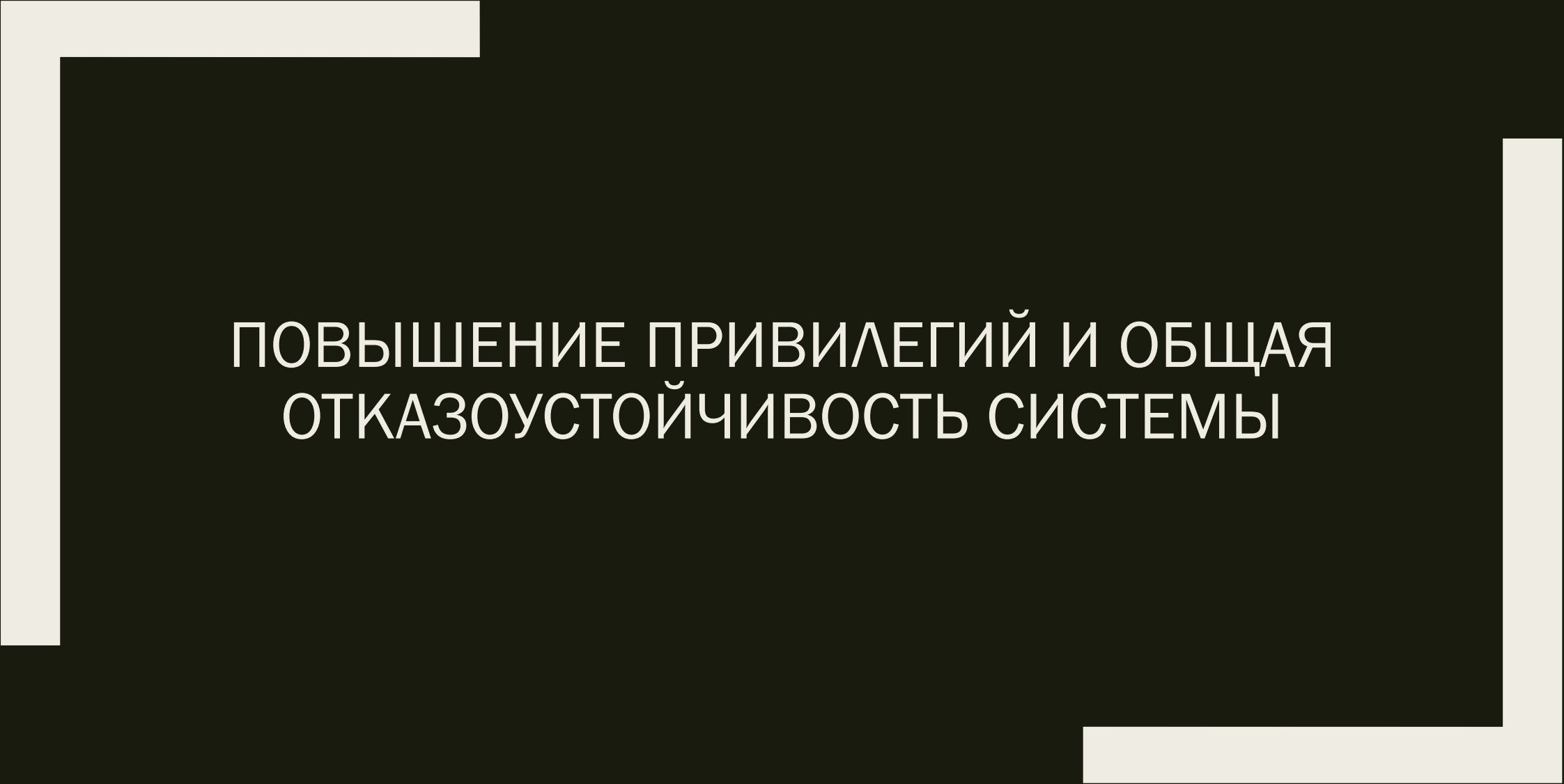




ПОВЫШЕНИЕ ПРИВИЛЕГИЙ И ОБЩАЯ
ОТКАЗОУСТОЙЧИВОСТЬ СИСТЕМЫ

Повышение привилегий

Повышение привилегий — это использование компьютерного бага, уязвимостей, ошибки в конфигурации операционной системы или программного обеспечения с целью повышения уровня доступа к вычислительным ресурсам, которые обычно защищены от пользователя. В итоге, приложение, обладающее большими полномочиями, чем предполагалось системным администратором, может совершать неавторизованные действия. «Повышением привилегий» называют ситуацию, когда пользователь компьютерной системы каким-либо образом повышает свои полномочия в этой системе (другими словами: получил возможность делать то, чего прежде делать не мог).

Повышение привилегий

Такая ошибка в программе, как внедрение кода через переполнение буфера, всегда нежелательна. Но, серьёзной эту ошибку можно считать лишь в том случае, если она повышает привилегии пользователя. В частности, если внедрение кода происходит на локальной машине, это привилегий не повышает: пользователь и без этого может выполнять исполняемые файлы. Если же удаётся внедрить код через сеть, это уже повышение привилегий: у пользователя появилась возможность выполнять машинный код.

Повышение привилегий

Переполнение буфера (англ. Buffer Overflow) — явление, возникающее, когда компьютерная программа записывает данные за пределами выделенного в памяти буфера.

Большинство компьютерных систем разрабатываются для использования несколькими пользователями. Полномочия пользователя означают те действия, которые пользователь в праве совершать. Обычно в такие действия входят просмотр и редактирование файлов или модификация системных файлов.

Повышение привилегий

Повышение привилегий означает, что пользователь получил привилегии, правами на которые он не обладает. Подобные привилегии могут быть использованы для удаления файлов, просмотра частной информации или для установки нежелательных программ (например, вредоносного ПО). Как правило это происходит, когда в системе присутствует определённая ошибка, которая позволяет обойти средства защиты компьютера. Выделяют две формы повышения привилегий:

Вертикальное повышение привилегий

Пользователь с низкими привилегиями или приложение имеет доступ к функциям, относящихся к более привилегированным пользователям или приложениям (например, когда пользователи Интернет-банкинга имеют доступ к административным функциям или знают способ обхода пароля по SMS).

Примеры вертикального повышения привилегий

В некоторых случаях, приложение с высоким уровнем доступа полагает, что на вход будут поступать данные, подходящие исключительно для её интерфейса, и не верифицирует их. В данном случае, кто угодно может подменить входящие данные так, что любой вредоносный код может быть запущен с привилегиями этого приложения.

Вертикальное повышение привилегий

Существуют ситуации, когда приложение может использовать более привилегированные источники и иметь неверное представление, как пользователь будет использовать эти источники. Например, приложения, которые могут вызывать командную строку, могут иметь уязвимость, если они используют непроверенные данные на входе, как часть выполняемой команды. Злоумышленник, в этом случае, сможет использовать системные команды с привилегиями данного приложения.

Горизонтальное повышение привилегий

Обычный пользователь имеет доступ к личным данным или функциям других пользователей (например, пользователь А имеет доступ к Интернет-Банкингу пользователя Б).

Примеры горизонтального повышения привилегий

Данная проблема часто возникает в веб-приложениях. Рассмотрим следующую ситуацию:

Пользователь А имеет доступ к его/ее счету в Интернет-банкинге.

Пользователь Б имеет доступ к его/ее счету в том же самом Интернет-банкинге.

Уязвимость возникает, когда пользователь А может получить доступ к аккаунту пользователя Б с помощью разного рода злонамеренных действий.

Данные действия возможны благодаря общим слабостям и уязвимости веб-приложений.

Горизонтальное повышение привилегий

Потенциальные слабые места веб-приложений и ситуации, которые могут привести к горизонтальному повышению привилегий:

- ❑ Предсказуемый идентификационный номер сессии в пользовательских файлах cookie
- ❑ Межсайтовый скриптинг (XSS) - тип атаки на веб-системы, заключающийся во внедрении в выдаваемую веб-системой страницу вредоносного кода и взаимодействии этого кода с веб-сервером злоумышленника. Является разновидностью атаки «Внедрение кода».

Горизонтальное повышение привилегий

- ❑ **Межсайтовая подделка запроса (CSRF)** - вид атак на посетителей веб-сайтов, использующий недостатки протокола HTTP. Если жертва заходит на сайт, созданный злоумышленником, от её лица тайно отправляется запрос на другой сервер, осуществляющий некую вредоносную операцию. Для осуществления данной атаки жертва должна быть аутентифицирована на том сервере, на который отправляется запрос, и этот запрос не должен требовать какого-либо подтверждения со стороны пользователя, которое не может быть проигнорировано или подделано атакующим скриптом.

Горизонтальное повышение привилегий

- ❑ Лёгкий пароль
- ❑ Кража файлов cookie
- ❑ Кейлогер - программное обеспечение или аппаратное устройство, регистрирующее различные действия пользователя — нажатия клавиш на клавиатуре компьютера, движения и нажатия клавиш мыши и т. д.
- ❑ Эксплойт - компьютерная программа, фрагмент программного кода или последовательность команд, использующие уязвимости в программном обеспечении и применяемые для проведения атаки на вычислительную систему. Целью атаки может быть как захват контроля над системой, так и нарушение её функционирования (DoS-атака).

Горизонтальное повышение привилегий

- ❑ **Бэкдор** – дефект алгоритма, который намеренно встраивается в него разработчиком и позволяет получить несанкционированный доступ к данным или удалённому управлению операционной системой и компьютером в целом.
- ❑ **Другое вредоносное ПО**

Способы защиты:

- ❑ Предотвращение выполнения данных - функция безопасности, встроенная в Linux, Mac OS X, Android и Windows, которая не позволяет приложению исполнять код из области памяти, помеченной как «только для данных». Она позволит предотвратить некоторые атаки, которые, например, сохраняют код в такой области с помощью переполнения буфера.
- ❑ ASLR технология - технология, применяемая в операционных системах, при использовании которой случайным образом изменяется расположение в адресном пространстве процесса важных структур данных, а именно образов исполняемого файла, подгружаемых библиотек, кучи и стека.

Способы защиты:

- ❑ Запускать приложения с минимальными привилегиями (например, Internet Explorer с отключенным SID) с целью предотвратить переполнение буфера
- ❑ Использование самых последних версий антивирусных программ
- ❑ Использование компиляторов, которые предотвращают переполнение буфера
- ❑ Кодирование программного обеспечения и/или его компонентов.

Отказоустойчивость

Отказоустойчивость — это способность системы продолжать полноценно работать при выходе из строя отдельных компонентов — серверов или каналов связи, сбоев на уровне отдельных модулей системы и т.д.

При этом стоит знать, что построение и сопровождение отказоустойчивой системы будет сложнее и дороже, нежели разработка и поддержка обычной системы. Подходить к проектированию каждого конкретного решения стоит с точки зрения экономической целесообразности. А для того, чтобы критерии принятия решения были объективны, нужны показатели, которые позволят измерить и сопоставить различные варианты.

Отказоустойчивость

Отказоустойчивость сложно измерить саму по себе, но измерению поддаётся аптайм — доступность сервиса, выраженная в процентах. Правильнее всего с точки зрения аналитики измерять аптайм за длительные интервалы — как минимум за год, а лучше — еще за больший интервал. Аптайм в диапазоне 99.8-99.9% — это нормальный показатель для обычных проектов на виртуальных хостингах или VPS — это примерно 1-2 часа неработоспособности в месяц или около 12 часов недоступности сервиса в год. Показатель около 99.95% — эквивалент 4 часов недоступности в год — уже достаточно хороший для односерверных инсталляций и для ПО, изначально не спроектированного для высокой отказоустойчивости. Если же требуемый уровень аптайма 99.99% и выше, то обычно требуется как построение соответствующей серверной инфраструктуры, так и модификация кодовой базы проекта для работы в режиме высокой отказоустойчивости.

Отказоустойчивость

Для обеспечения нормального уровня доступности не нужно строить отказоустойчивую систему: достаточно просто качественно написанного кода приложения, адекватных процессов сопровождения, рекомендуется пользоваться услугами профессиональных хостинговых компаний — они резервируют каналы связи, питание и охлаждение оборудования, а также для односерверных инсталляций использовать надежные выделенные сервера — лучше физические, а не виртуальные.

Отказоустойчивость

Для достижения высокого уровня доступности уже используются механики построения отказоустойчивых систем — в частности, дублирование всех критичных подсистем, что позволяет приложению функционировать, даже если из строя выходит один из компонентов. Основных способа тут два — горизонтальное масштабирование или дублирование всех серверов и настройка их автоматической "горячей" замены. И в том, и в другом случае выполняется дублирование всех критичных компонентов системы, разница лишь в штатных режимах работы и в механике обеспечения отказоустойчивости. При горизонтальном масштабировании компоненты работают параллельно и это к тому же повышает устойчивость к нагрузкам, а при использовании схемы с «горячей заменой» резервный компонент включается только в момент выхода из строя основного. Горизонтальное масштабирование обычно более привлекательно с точки зрения утилизации мощностей, но применимо оно не везде и часто требует более существенных доработок ПО для реализации.